

Trevon Woods
ITAI - 3377 - A.I. at the Edge
Sitaram Ayyagari
04/04/2026

Cybersecurity Plan for an AI-Integrated Smart Factory

System Design & Vulnerability Identification

System Selection

- a. I decided to design, implement, and assess a comprehensive cybersecurity plan for a hypothetical AI-Integrated smart factory. I chose this path because I believe manufacturing is the main industry that will be, if not already, impacted the most by the advancements of AI. Especially in the use of IoT devices that contain PLCs (Programmable Logic Controllers). These IoT devices can use sensors to gather data by monitoring minute reactions. Then the data can be processed by an AI algorithm to help the PLC devices make appropriate actions or simply give warnings to specialists monitoring these systems about impending failures.

System Components

- a. **Devices and Sensors**

1. Temperature, vibration, pressure sensors
2. Smart PLCs
3. Industrial robots

- b. **AI Models**

1. Predictive maintenance models
2. Anomaly detection models
3. Quality control vision systems

- c. **Network Infrastructure**

1. Industrial Ethernet
2. Wi-Fi / 5G gateways
3. Edge computing nodes
4. Cloud servers

- d. **Data Flow**

Sensors → Edge Gateway → AI Model (Edge/Cloud) → Dashboard → Operator
Actions

Vulnerability Assessment

a. Device Vulnerabilities

1. Weak firmware security

- i. This vulnerability allows attackers to upload malicious firmware to the system giving them unauthorized access.

2. Default credentials

- i. This vulnerability allows an attacker to gain unauthorized access simply because the victim uses unchanged or default passwords.

3. Physical tampering

- i. This is when an attacker directly manipulates sensors or PLCs connected to the system.

b. Network Vulnerabilities

1. Unencrypted communication

- i. Man-in-the-Middle (MITM) attacks happen when an attacker places themselves in the middle of network traffic going in and out of the system.

2. Insecure protocols (e.g., Modbus TCP)

- i. This is an attack where an attacker performs Packet Injection or replay attacks. Replay attacks are when an attacker records a victim's activity like logging into a website and replays their login credentials at a later time to gain unauthorized access.

3. Poor network segmentation

- i. This is a vulnerability that allows an attacker to have lateral movement across systems. In other words because all devices are connected to the same network they are easily discoverable and traversable.

c. Data Vulnerabilities

1. Data leakage

- i. This vulnerability is when data is not stored securely making it easy for an attacker to perform operational exfiltration of sensitive data.

2. Data poisoning

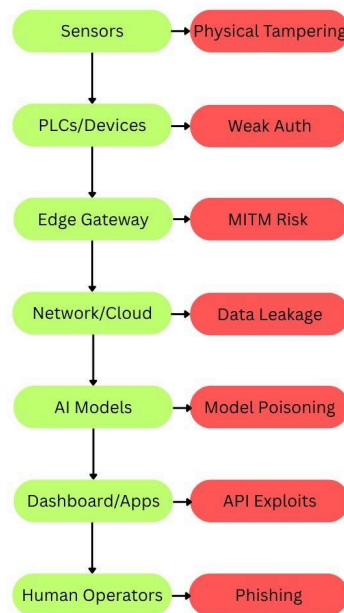
- i. This is an attack typically associated with the preprocessing of AI/ML datasets. Attackers inject false data into training sets to ensure that the models trained on it are biased toward their poison.

d. AI Model Vulnerabilities

1. Model poisoning

- i. This attack is similar to data poisoning but the attackers corrupt the model's weights/parameters to degrade predictions.
 - 2. **Adversarial attacks**
 - i. This attack is similar to data poisoning but is usually associated with the prompting of an AI model. These poisoned prompts corrupt model thinking causing wrong predictions.
 - 3. **Model theft**
 - i. This is a vulnerability that allows an attacker to copy, steal, or replicate proprietary models. This is interesting because there is a technique called Knowledge Distillation that is commonly used to train models. It involves copying the larger models' thinking and stealing its answers which essentially replicates the model.
- e. **Application Vulnerabilities**
- 1. **Insecure APIs**
 - i. This vulnerability allows an attacker unauthorized data access to an app because the victim's API has weak security measures.
 - 2. **Lack of input validation**
 - i. This attack involves the application not having proper input sanitization and validation in place. Without these in place an attacker can perform Injection Attacks. By sending malicious inputs/code to an apps backend/database, this attacker can gain unauthorized access.
- f. **Human Vulnerabilities**
- 1. **Phishing attacks**
 - i. An attacker can use this sophisticated social engineering technique to impersonate someone of importance in an organization through email, text, or phone to steal sensitive information.
 - 2. **Poor password practices**
 - i. This is when a business doesn't implement policies that require the creation of complex passwords for systems.
 - 3. **Insider threats**
 - i. When the attacks come from employees or authorized individuals. An example could be the Snowden situation a decade ago where he gained access to government servers to extract information from the inside.

System Diagram



Defense Strategy Development

Defense Measures

a. Secure by Design

- a. Zero Trust
- b. Least privilege
- c. Secure boot

b. Authentication & Access Control

- a. Multi-Factor Authentication
- b. RBAC (Role-Based Access Control)
- c. Device identity certificates

c. Encryption & Data Protection

- a. TLS encryption
- b. AES-256 for stored data
- c. Secure key management systems

d. Network Security

- a. Network segmentation
- b. Firewalls + Intrusion Detection Systems
- c. VPN for remote access

- e. **Secure Software Development**
 - a. Code reviews & static analysis
 - b. Regular patching and updates
 - c. API authentication
- f. **Physical Security**
 - a. Restricted access to factory floor
 - b. Tamper-resistant hardware
 - c. Surveillance systems
- g. **Monitoring & Incident Response**
 - a. SIEM
 - b. Real-time anomaly detection
 - c. Incident response playbooks
- h. **AI-Specific Security**
 - a. Secure training pipelines
 - b. Dataset validation
 - c. Model versioning & auditing
 - d. Adversarial input detection

Implementation Plan

Step 1: Assessment (Weeks 1-2)

1. Identify assets and vulnerabilities
2. Perform risk analysis
3. Assign roles:
 - a. Security Analyst
 - b. Network Engineer
 - c. AI Engineer

Step 2: Infrastructure Security (Weeks 3-6)

1. Implement network segmentation
2. Deploy firewalls and IDS
3. Configure secure communication (TLS)

Step 3: Access Control (Weeks 5-7)

1. Set up MFA and RBAC

2. Replace default credentials
3. Issue device certificates

Step 4: AI Security (Weeks 6-9)

1. Validate datasets
2. Secure training pipelines
3. Implement adversarial detection

Step 5: Monitoring & Response (Weeks 8-10)

1. Deploy SIEM tools (e.g., Splunk, ELK Stack)
2. Create alert rules
3. Develop incident response plan

Step 6: Testing & Training (Weeks 10-12)

1. Penetration testing
2. Red team exercises
3. Employee cybersecurity training

Technologies & Tools

1. **Network Security:** Cisco, Palo Alto Firewalls
2. **Monitoring:** Splunk, ELK Stack
3. **Encryption:** OpenSSL, AWS KMS
4. **AI Security:** TensorFlow Privacy, IBM Adversarial Robustness Toolbox

Penetration Testing Simulation

Default Credentials Exploit

- **Attack**
 - This attack calls for the attacker to use brute-force by running a program called Hydra using a text file that contains commonly used passwords. This is the command that an attacker might use: `hydra -l admin -P passwords.txt ssh://target_ip`. They can also just try default credentials like `admin/admin` or `root/root` to gain access to the IoT system.
- **Defense**
 - The first defense in place includes applying Multi-factor Authentication mechanisms that require anyone trying to gain access to provide multiple forms of verification. Secondly, enabling a policy that requires all users to

create strong passwords will remove the threat of brute force attacks using commonly used passwords. Lastly, the implementation of IDS systems, and/or Anomaly detection AI programs, will be monitoring system processes to notice any attacker's attempts to gain unauthorized access to the system.

- **Effectiveness, Weakness, and Improvements**

- I believe the defense mechanisms in place are very effective for the detection of attacks to gain unauthorized access to the device. Moreover, the system has multiple levels of verification that gives it a higher chance of flagging suspicious activity. As for a weakness of the system based on this attack, there is no mechanism to lock out the attacker after repeated attempts were made. Furthermore, if someone sets a weak or default password then there is very little any security measure could do to prevent unauthorized access to the device. To improve the system there needs to be an enforcement of more complex passwords and the implementation of rate limiting. Rate limiting will deny anyone making more than a pre-defined amount of attempts to gain access to the system and failing.

Man-in-the-Middle Exploit

- **Attack**

- This attack calls for the attacker to position themselves in the middle of the traffic being passed between the device and the dashboard or wherever the data is being sent. This is done using a networking tool specifically for intercepting internet traffic, Arpspoof. It forges ARP replies, linking the attackers MAC address with a target's IP address. Then the attacker uses something like Wireshark to sniff the network packets and view the information being sent. The typical command to use Arpspoof is:
`arpspoof -t target_ip gateway_ip` then using the command `wireshark` to sniff packets.

- **Defense**

- The defense that has been put in place is TLS encryption and the use of secure protocols like MQTT over TLS.

- **Effectiveness, Weaknesses, and Improvements**

- The defense is effective against most attacks of this nature, but may struggle with more nuanced or sophisticated approaches. Still, encrypting your TLS will usually do the trick as there are not many zero day exploits of TLS just floating around. The weakness is obviously if the data is not

encrypted before transfer. Another weakness could be if the system does not implement certification validation. For improvements, I would need to start by enforcing TLS 1.2+. Then setup the system to use certificate pinning which is a security mechanism that associates a specific server's expected SSL/TLS certificate or public key with a client application. Finally, I would need to Disable all insecure protocols to ensure that the data does not get intercepted during transfer.

Individual Reflection

Learning Experience

- I learned a few things from this assignment that I feel will really help me if I ever enter the manufacturing space for AI. First was the breadth of the entire system architecture. I initially thought that all there was to it was attaching the IoT device to the machinery and then sending the data to a database to be viewed in a dashboard. Now I understand why it is so important to develop a security plan so your system data remains safe. I also enjoyed the Pentesting simulation as well because it was like looking at a chess board from both sides to see how attacks are implemented and the preventative measures to combat them. For example the MITM simulation revealed that unencrypted communication would make it easy for a malicious actor to intercept the sensor data. Through the use of TLS encryption, any intercepted traffic would be unreadable which would improve the system's confidentiality.

Proposed Improvements

- **Authentication & Access Control**
 - I propose the implementation of a strong authentication & access control mechanism to be put in place. It could help with the enforcement of strong password policies that specify complexity, length, and expiration. Then MFA and systems that lockout users after failed attempts due to the implementation of rate limiting combating the use of brute force attacks on the system.
- **Network Security**
 - To enhance network security there would need to be proper network segmentation in place to separate IT, OT, and AI systems. Then I would need to use TLS 1.2+ encryption for all communications over any protocol to ensure that traffic is not able to be sniffed and viewed by unauthorized persons. Finally, the deployment of firewalls, IDS/IPS systems, and secure gateways between edge and cloud architectures are necessary to ensure malicious activity is stopped or caught in its tracks.

- **AI Model Security**

- The first thing that needs to be implemented would be data validation pipelines that check for range and outlier data. Also the oversight to ensure that only trusted data sources are used to create datasets to train models is very important to ensure that the data can be trusted. The addition of monitoring mechanisms could also help detect drops in model accuracy. Through this detection and proper logging I would be able to determine what or who caused the drop.

- **Data Protection**

- To ensure that there are no data leakages or lack of encryption the first thing that should be implemented is RBAC (Role-based access control). This will ensure that only authorized individuals have access to important data. The use of secure key management systems like Cloud KMS (AWS, Google, Azure) are very important to ensure the safe storage of secret keys. Finally, the application of data anonymization whenever possible is very important to make sure that PII information does not get leaked.

- **Application & API Security**

- In order to combat the risks of injection attacks and easy access due to weak API security, the first improvement would be input validation and sanitization. This will ensure that any data being sent to the systems backend/database is not malicious in nature and doesn't contain code that could execute harmful actions. Lastly, to secure the API the implementation of OAuth 2.0 or token-based authentication would be a huge help toward correctly authorizing users.

- **Improvement of Human Vulnerabilities**

- Human vulnerabilities are more common than you think. The only way to ensure that employees aren't susceptible to phishing or lack security awareness would be to conduct regular cybersecurity training. Having them run simulated scenarios for different attacks would strengthen their awareness and reduce their gullibility as well. Furthermore, the enforcement of least privilege access and the establishment of clear security policies for everyone to follow are extremely necessary.

Conclusion

- Overall this assignment was very thought provoking and a great look at what it takes to secure an IoT device. I learned that security has many layers in these systems and attention to detail is very important. In the future I want to take a

look at what all goes into Healthcare monitoring systems and connected transportation networks.